

Phishing Analysis and Awareness

Date:25/06/2026

Contents

1. Executive Summary.....	3
2. Methodology.....	4
3. Phishing Email Sample Analysis.....	6
4. Common Phishing Indicators.....	9
5. Risk Classification Matrix.....	12
6. Prevention & Awareness.....	14
7. Employee Security Awareness Tips.....	18
8. Solution if clicked.....	20
9. Reference and Further reading.....	21
10. Recommendations.....	23
11. Conclusion.....	24

1. Executive Summary

Phishing remains the most prevalent initial attack vector in cybersecurity. According to the Hoxhunt Phishing Trends Report (2026), 56% of phishing emails analysed in December 2025 showed indicators of AI assistance making them harder to distinguish from legitimate communications. This report analyzes real phishing email samples, identifies common indicators of compromise (IOCs), classifies risk levels, and provides actionable prevention guidelines for end users and security teams.

2. Methodology

Tools Used

Tool	Purpose	URL
Google Admin Toolbox - Messageheader	Email header parsing and route tracing	https://toolbox.googleapps.com/apps/messageheader/
MxToolbox Email Header Analyzer	RFC 822 header parsing, SPF/DKIM/DMARC validation	https://mxtoolbox.com/EmailHeaders.aspx
VirusTotal	URL and attachment hash reputation checking	https://www.virustotal.com
CanIPhish Dataset	Real phishing email template library	https://caniphish.com/phishing-email-examples
GitHub Reference Repositories	Real-world phishing EML samples	See References section
Manual Header Analysis	Received path tracing, IP geolocation, MIME inspection	—

Analysis Process

1. Collect email sample (EML/MSG format)
2. Extract and parse email headers
3. Trace Received path from bottom to top

4. Validate SPF, DKIM, DMARC authentication
5. Inspect sender domain and display name for mismatches
6. Extract URLs and attachments (sandbox analysis)
7. Check IP/domain reputation on blacklists
8. Identify social engineering tactics in body text
9. Classify risk (Safe / Suspicious / Phishing)
10. Document findings

3. Phishing Email Sample Analysis

Sample 1: Account Lock Verification Scam

Subject: Urgent: Your Account Will be blocked

Body:

Dear User,

We noticed suspicious activity on your account.

To avoid account suspension, please verify your details immediately.

Verify Now: [http://secure-account-verify\[.\]com](http://secure-account-verify[.]com)

Failure to verify within 24 hours will result in permanent account lock.

Regards,

Security Team

Risk Classification: PHISHING – HIGH

Indicator	Finding
Sender Domain	Generic webmail or misspelled corporate domain (not shown, but assumed from pattern)
Greeting	"Dear User" – generic, no personalization
Urgency	"24 hours," "permanent account lock" – fear-based urgency
Link	Suspicious domain not matching the purported company
Request	Asks for credentials/verification – legitimate companies never do this

--	--

How the Attack Works:

The attacker sends mass emails posing as a security or IT team. The victim clicks the link, lands on a fake login page (spoofed to look like the real company), enters their credentials, and the attacker captures them. Within minutes, the attacker can access the victim's real account.

Sample #2: Fake Fax/SharePoint Notification (Real EML from GitHub)

Source: autinerd/phishing-mail-examples (anonymised)

Subject: (No clear subject — fax notification)

From: "WirelessReceived" (spoofed display name)

Return-Path: attack@attacker.example.com

Body Summary: Claims to be a SharePoint fax notification from "MetroFax" — includes a "Print & Preview Here" link pointing to attacker.example.com

Risk Classification: PHISHING — HIGH

Indicator	Finding
Display Name Mismatch	"WirelessReceived" repeated — not a legitimate sender name
SPF	Fail (sender IP 192.0.2.1 not authorized)
DKIM	None (message not signed)

DMARC	Fail
Return-Path	attack@attacker.example.com — not a legitimate domain
Link	Points to attacker.example.com, masquerading as MetroFax
Greeting	None — no personalization
Attachment Claim	Claims PDF attachment but link leads to phishing site
Sender Domain	attacker.example.com — not affiliated with MetroFax or SharePoint

How the Attack Works:

The attacker impersonates a fax service (MetroFax) and uses SharePoint branding to appear legitimate. The email creates curiosity ("You have a new fax!") and prompts the user to click a link. The link leads to a credential harvesting page or a malware download site. Since fax and document notifications are common in business environments, users rarely question them.

4. Common Phishing Indicators (The 14 Red Flags)

Based on analysis of 50+ real phishing email samples and industry research (Hoxhunt, Keepnet, CanIPhish):

Technical indicators (Header & Infrastructure)

#	Indicator	What to Check
1	SPF Failure	Sending server IP not authorized to send for the domain
2	DKIM Missing/Failure	Email not cryptographically signed by the sender domain
3	DMARC Failure	Authentication policy not aligned or enforced
4	Display Name vs. Domain Mismatch	"PayPal" but from random@gmail.com
5	Suspicious Received Path	Email routed through unknown or foreign servers
6	Return-Path ≠ From Address	Bounce address doesn't match sender address
7	Reply-To Header Altered	Replying goes to a different address

8	Unusual Message-ID Format	Random or repetitive patterns suggesting mass mailing
---	---------------------------	---

Social Engineering Indicators

#	Indicator	Example
9	Urgency / Fear-Based Language	"Account will be locked in 24 hours"
10	Generic Greeting	"Dear User," "Dear Customer," "Dear Sir/Madam"
11	Suspicious Links	Hover shows different URL than displayed text; misspelled domains (g00gle.com, micrOsoft.com)
12	Unsolicited Attachments	Unexpected PDF, DOCX with macros, ZIP, or .JS files
13	Request for Credentials/Payment	"Verify your account," "Confirm your password"
14	Poor Grammar / Spelling Errors	Although AI-generated emails now have fewer errors, look for awkward phrasing

Advanced Red Flags(2026)

#	Indicator	Note
—	QR Codes (Quishing)	Bypasses email link scanners; directs users to phishing sites via mobile
—	AI-Generated Content	Check for generic HTML section markers like "Main Content," "Click to Call" in source
—	Open Redirect Abuse	Legitimate sites (Google, LinkedIn) used to redirect to malicious pages
—	Unicode Homoglyphs	Letters replaced with visually similar characters from other scripts

5. Risk Classification Matrix

Category	Criteria	Action
SAFE	SPF/DKIM/DMARC all pass; sender domain matches known legitimate domain; no suspicious links or attachments; personalized greeting with correct name; no urgency pressure	No action needed
SUSPICIOUS	Minor red flags (e.g., SPF softfail, generic greeting but otherwise legitimate-looking); no malicious payload confirmed	Verify via alternative channel (call the sender); report to security team for review
PHISHING	Multiple red flags present: SPF/DKIM/DMARC fail or mismatched; display name $\neq$ domain; urgent request for credentials/payment; suspicious links	Do NOT click any links or open attachments; report immediately to security team; delete the email

	or attachments; generic greeting	
--	-------------------------------------	--

6. Prevention & Awareness Guidelines

Do's & Don'ts For Employees

DO

Action	Explanation
Hover before you click	Hover your mouse over any link to see the actual URL before clicking. If it doesn't match the company domain, don't click.
Verify via alternate channel	If an email asks for sensitive information or urgently requests action, call the sender using a phone number you already know (not one from the email).
Report suspicious emails	Use your company's "Report Phishing" button. Every report helps train the security filters.
Check the sender's full email address	Look at the actual email address, not just the display name. "PayPal" <ppal4321@gmail.com> is a scam.
Enable Multi-Factor Authentication (MFA)	MFA stops attackers even if they steal your password. Prefer authenticator apps or hardware keys over SMS.
Keep software updated	Phishing attacks often lead to malware that exploits known vulnerabilities. Updates close

	those gaps.
Pause and think	Attackers create urgency to bypass your critical thinking. Take 10 seconds to evaluate before acting.

DON'T

Action	Why It's Dangerous
Click links in unsolicited emails	Even if the email looks legitimate, manually type the company URL into your browser instead.
Open unexpected attachments	Attachments can contain malware, ransomware, or credential stealers. Verify with the sender first.
Share passwords or OTPs via email	No legitimate company will ever ask for your password or one-time code by email.
Reply to suspicious emails	Replying confirms your email address is valid, leading to more targeted attacks.
Scan unknown QR codes	QR codes can lead directly to phishing pages without showing a URL first.
Bypass security warnings	If your browser or email client shows a warning, listen to it.
Use work email for personal accounts	If the personal account gets breached, attackers can impersonate you professionally.

Quick Decision Flowchart

You receive an email

|



Is the sender's email address legitimate?

|

|

|

|

YES

NO

|

|



Does the email request sensitive info or urgent action?

|

|

|

|

NO

YES

|

|



Safe Is the request unusual or unexpected?

|

|

YES	NO

▼	▼

Verify via Likely safe
phone/Slack but monitor
before acting

7. Employee Security Awareness Tips

"The 5-Second Phishing Check"

When you see an email that makes you feel urgent, scared, curious, or excited —stop for 5 seconds and ask:

1. Who sent this? — Is the email address from the real company, or is it a misspelled version?
2. What are they asking for? — Passwords, money, personal info? Legitimate companies don't ask for these via email.
3. Where does the link go? — Hover over it. Does the URL match the company's real website?
4. Is this too good to be true? — "You won a prize!" "\$500 gift card!" "Exclusive bonus!" — these are almost always scams.
5. Does it feel rushed? — "Act now!" "Limited time!" "Your account will be deleted!" — urgency is a scammer's best tool.

Common Phishing Themes to Watch For in 2026

Package delivery scams — "Your DHL/FedEx package is waiting — pay \$2.99 to release it"

HR/Benefits updates— "Updated payslip," "Open enrollment requires action"

IT helpdesk impersonation— "Mailbox full," "Password expires today," "MFA re-registration"

Executive impersonation (Whaling) — "CEO needs you to buy gift cards / wire transfer urgently"

File sharing notifications — "Manager shared a confidential file with you"

SaaS/MFA alerts — "Suspicious sign-in detected — verify your account"

QR code scams (Quishing) — "Scan this code to redeem your voucher / view your document"

8. What To Do If You Clicked a Phishing Link

Don't panic. Act quickly.

1. Disconnect from the network — Unplug Ethernet or turn off Wi-Fi immediately.
2. Do not enter any more information — Close the browser tab.
3. Change your password — Use a different, clean device (e.g., your phone) to change the password for the affected account.
4. Enable/check MFA — Make sure multi-factor authentication is active.
5. Contact your IT/SOC team immediately — They can check for unauthorized access and scan your device.
6. Run a security scan — Use your organization's approved antivirus/EDR tool.
7. Monitor for unusual activity — Keep an eye on account activity for the next few weeks.

9. Reference & Further Readings

Resource	URL
CanIPhish — 50+ Phishing Email Examples	https://caniphish.com/phishing-email-examples
Hoxhunt — 14 Phishing Red Flags (2026)	https://hoxhunt.com/blog/phishing-red-flags
Hoxhunt — Phishing Trends Report 2026	https://hoxhunt.com/guide/phishing-trends-report
Keepnet Labs — Email Header Analysis Guide	https://keepnetlabs.com/blog/how-to-do-phishing-email-header-analysis
MxToolbox — Email Header Analyzer	https://mxtoolbox.com/EmailHeaders.aspx
Google Admin Toolbox — Messageheader	https://toolbox.googleapps.com/apps/messageheader/
GitHub — Phishing Email Examples (autinerd)	https://github.com/autinerd/phishing-mail-examples
GitHub — Phishing Database (domains/URLs)	https://github.com/Phishing-Database/Phishing.Database
GitHub — Phishing_Email Dataset	https://github.com/sadat1971/Phishing_Email
Seraphic Security — Phishing Attack Patterns 2025	https://seraphicsecurity.com/learn/website-security/phishing-attacks-in-2025-10-attack-patterns-examples-and-defenses/

Abnormal Security — Email Header
Guide

<https://abnormal.ai/blog/what-is-an-email-header>

Recommendations For Organisations

1. Deploy advanced email security with sandboxing, URL rewriting, and real-time threat intelligence feeds.
2. Enforce SPF, DKIM, and DMARC with a reject/quarantine policy for all outbound domains.
3. Conduct phishing simulations at least monthly, using varied scenarios tailored by department.
4. Train employees continuously — not just annual compliance. Micro-learning sessions (2-3 minutes) are more effective than hour-long lectures.
5. Make reporting easy — a one-click "Report Phishing" button that routes to SOC with auto-triage.
6. Implement phishing-resistant MFA (FIDO2/WebAuthn hardware keys) for high-risk roles (finance, IT, executives).
7. Monitor for lookalike domains and use automated takedown services to remove impersonating sites.
8. Create a clear incident response playbook for phishing: what to do when an employee clicks, enters credentials, or opens a malicious attachment.

CONCLUSION

Phishing remains the single most dangerous and cost-effective attack vector for cybercriminals — not because systems are weak, but because **human behavior is predictable**. Every phishing email analysed in this report follows the same fundamental playbook: create urgency, impersonate a trusted entity, and trick the user into acting before thinking.

The real-world samples we analysed — the fake fax notification, the spoofed voice message, the Outlook invoice scam — all share common DNA:

- Authentication failures (SPF/DKIM/DMARC failing or misaligned)
- Display name deception (showing a trusted brand while hiding a malicious domain)
- Psychological manipulation (fear of account loss, curiosity about a "fax," financial urgency)

The emergence of AI-generated phishing and QR code attacks in 2025–2026 has raised the bar significantly. Attackers no longer need to rely on poor grammar or obvious typos. Their emails now look cleaner, feel more personalized, and blend into daily workflows with alarming effectiveness.

The key takeaway is this: Technology alone cannot solve phishing. Email filters, SPF records, and DMARC policies will stop some attacks, but determined attackers will always find a way through. The strongest defense is a trained, skeptical, and empowered workforce that knows how to pause, verify, and report.

Organizations that invest in continuous security awareness training — not a once-a-year checkbox exercise — build a human firewall that adapts as fast as the threat landscape evolves. Combine that

with phishing-resistant MFA, clear reporting channels, and a culture where "better safe than sorry" is celebrated, and you turn your employees from your biggest risk into your most effective detection system.

In short: Phishing works because it targets trust. The solution is not to eliminate trust — it's to verify before you trust.